



# LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



## CaptiveCrunch Hospitality Wi-Fi Credential Theft and Malware Delivery

### Threat Report

|                       |                 |
|-----------------------|-----------------|
| <b>Classification</b> | TLP:CLEAR       |
| <b>Published</b>      | 2026-08-04      |
| <b>Version</b>        | 1.0             |
| <b>Author</b>         | Lost Boys Cyber |
| <b>Report Type</b>    | Threat Report   |

TLP:CLEAR | Lost Boys Cyber | CaptiveCrunch Hospitality Wi-Fi Credential Theft and Malware Delivery - Threat Report

Published: 2026-08-04 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

## Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Activity Overview
5. Affected Sectors and Exposure
6. Tactics, Techniques, and Procedures
7. Infrastructure and Indicators
8. Malware and Tooling Notes
  - 8.1. CornFlake
  - 8.2. ChocoShell
  - 8.3. FruitStone
9. Detection Engineering
  - 9.1. Detection Summary
  - 9.2. Sigma: CornFlake Persistence Service
  - 9.3. Sigma: ChocoShell PowerShell C2 Indicators
  - 9.4. YARA: CaptiveCrunch Public Artifact Strings
  - 9.5. KQL: Known Infrastructure Contact
  - 9.6. KQL: Download After Captive-Portal Connectivity Check
10. Threat Hunting
  - 10.1. Hunt Hypothesis 1: Captive portal redirected a traveler to malicious infrastructure
  - 10.2. Hunt Hypothesis 2: CornFlake persistence was installed under the masqueraded Cloud Sync service
  - 10.3. Hunt Hypothesis 3: Device-code authentication was abused during travel
  - 10.4. Hunt Hypothesis 4: PowerShell attempted ChocoShell-style token theft or C2
11. Risk Assessment
12. Recommended Actions
13. Incident Response Playbook
14. MITRE ATT&CK Mapping
15. References

# CaptiveCrunch Hospitality Wi-Fi Credential Theft and Malware Delivery

## 1. Executive Summary

CaptiveCrunch is an active traffic-manipulation and credential-theft campaign attributed by Microsoft Threat Intelligence to Storm-2945, an operational sub-cluster of Midnight Blizzard/APT29. Since early May 2026, Microsoft observed the actor manipulating DNS and HTTP traffic on hospitality and other captive-portal networks to redirect travelers into phishing pages, device-code authentication abuse, and fake update workflows that deliver malware. The activity matters because it turns a high-trust travel routine—joining hotel or conference Wi-Fi—into an adversary-controlled initial access point.

The campaign combines three risk paths: adversary-in-the-middle (AitM) Microsoft 365 phishing, Microsoft Entra ID device-code phishing, and ClickFix-style malware delivery. Reported tooling includes CornFlake, a Go-based Windows RAT and infostealer with persistence, surveillance, browser credential theft, removable-media monitoring, and remote shell capability; ChocoShell, an in-memory PowerShell infostealer focused on browser sessions, Microsoft 365/Azure tokens, and Wi-Fi credentials; and FruitStone, a web-based operator panel branded as a fake CloudSync Console.

Defenders should treat hospitality Wi-Fi as untrusted infrastructure, especially for executive, government, diplomatic, NGO, defense, and IT-service-provider travelers. Immediate priorities are to prefer cellular or managed full-tunnel connectivity, block or strictly scope device-code flow where possible, hunt for the published domains/IPs/hashes, alert on suspicious downloads immediately after captive-portal connectivity checks, and detect CornFlake persistence artifacts such as `%APPDATA%\svchost32\svchost32.exe`, service `svchost32`, display name `Cloud Sync Service`, and registry/service/scheduled-task persistence.

## 2. Intelligence Requirements

| Question                  | Current Answer                                                                                                                                                                               | Confidence |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|
| What is CaptiveCrunch?    | A Storm-2945 campaign abusing captive-portal networks to redirect travelers to phishing, device-code abuse, and fake update malware delivery.                                                | High       |
| Who is attributed?        | Microsoft assesses Storm-2945 as an operational sub-cluster of Midnight Blizzard/APT29, associated by US/UK governments with Russia's SVR.                                                   | High       |
| Who is exposed?           | Travelers using hotel, conference, airport, and shared-venue Wi-Fi; corporate accounts are especially exposed when Microsoft 365/Entra identity is reachable from unmanaged travel networks. | High       |
| What is locally verified? | This report is OSINT-backed. No malware sample or victim telemetry was provided, so detections are source-derived and should be validated against client telemetry.                          | High       |

## 3. Source Review & Confidence

| Source                              | Contribution                                                                                                                      | Confidence |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|------------|
| Microsoft Security Blog, 2026-07-31 | Primary campaign disclosure, attribution, malware/tooling details, Microsoft Defender detections, hunting queries, and IOC table. | High       |

|                                              |                                                                                                                                                                 |        |
|----------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| ReliaQuest reporting referenced by Microsoft | Earlier public reporting on DNS poisoning tactics expanding to hospitality; Microsoft cites it for part of the activity and venue context.                      | Medium |
| The Hacker News, 2026-08-01/04               | Secondary summary with emphasis on DNS resolver/captive gateway control, ClickFix execution requirement, device-code abuse, and CornFlake/ChocoShell artifacts. | Medium |
| Help Net Security, 2026-08-04                | Secondary corroboration of campaign flow, malware names, affected hospitality networks, and defensive recommendations.                                          | Medium |
| Malwarebytes, 2026-08-04                     | Traveler-facing impact explanation and recap of fake update dialog lures and credential-stealing objectives.                                                    | Medium |

## 4. Threat Activity Overview

CaptiveCrunch targets users at the network edge rather than starting with a conventional email lure. On compromised captive-portal networks, the attacker can manipulate DNS and HTTP traffic encountered when devices test connectivity or when users browse after joining guest Wi-Fi. Microsoft reports commonalities in equipment and management systems across affected networks, raising the possibility of shared-service compromise within parts of the captive-portal ecosystem rather than isolated compromise at individual venues.

Observed redirection outcomes include:

| Path                        | User Experience                                                                                 | Attacker Objective                                                        | Defensive Interpretation                                                                   |
|-----------------------------|-------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| AitM Microsoft 365 phishing | User lands on a fake Microsoft online service or sign-in page.                                  | Harvest credentials, sessions, or OAuth artifacts.                        | Treat as network-originated phishing; email controls may never see a lure.                 |
| Device-code phishing        | User is instructed to enter an attacker-provided code into a legitimate Microsoft sign-in flow. | MFA-satisfied cloud session for the actor-controlled device/code request. | Device-code flow should be blocked or tightly scoped; successful auth may look legitimate. |
| ClickFix/fake updates       | User sees fake browser/OS/utility update prompts and paste-and-run instructions.                | Deliver CornFlake, ChocoShell, or related tooling.                        | Execution still requires user action, but captive portal context increases plausibility.   |

Microsoft also reports indications of Android-targeting landings using APK download/install instructions. Public reporting does not provide enough detail to assess Android payload scale or maturity, so this report treats Android targeting as a watch item rather than a confirmed dominant path.

## 5. Affected Sectors and Exposure

| Exposure Group                          | Why CaptiveCrunch Matters                                                                             | Priority |
|-----------------------------------------|-------------------------------------------------------------------------------------------------------|----------|
| Executive and privileged travelers      | High-value accounts may authenticate from hotel/conference Wi-Fi and carry broader SaaS/cloud access. | Critical |
| Government, diplomatic, NGO, and policy | These align with Midnight Blizzard's                                                                  | Critical |

|                                                    |                                                                                                                      |      |
|----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|------|
| organizations                                      | longstanding espionage collection priorities.                                                                        |      |
| IT service providers and managed service providers | Compromised identities can become downstream client-access pivots.                                                   | High |
| Corporate conference attendees                     | Shared venues and captive portals create many same-day high-value targets behind common infrastructure.              | High |
| Hospitality operators and captive-portal providers | Network management or shared service compromise can turn guest infrastructure into a credential-harvesting platform. | High |
| BYOD and unmanaged travel devices                  | Reduced EDR, VPN, and identity enforcement increases risk from fake updates and token theft.                         | High |

## 6. Tactics, Techniques, and Procedures

| Tactic / Phase      | Observed Technique                                                                        | Evidence                                                                                                                                                               |
|---------------------|-------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Initial Access      | Captive-portal DNS/HTTP manipulation and redirection                                      | Microsoft observed traffic manipulation on captive-portal networks since early May 2026.                                                                               |
| Initial Access      | AitM phishing with Microsoft-themed doppelganger domains                                  | Published IOCs include `ms365-device[.]com`, `ms365-live[.]com`, `m365-owa[.]com`, and `owa-ms365[.]com`.                                                              |
| Credential Access   | Microsoft Entra device-code phishing                                                      | Microsoft reports CaptiveCrunch landings redirecting users into device-code authentication flow since July 16.                                                         |
| Execution           | ClickFix-style paste-and-run or fake update social engineering                            | Microsoft and secondary reporting describe fake Windows update, Defender, DirectX, Visual C++ redistributable, network fix, browser update, and document viewer lures. |
| Persistence         | CornFlake service, Run key, scheduled task, and watchdog persistence                      | CornFlake copies to `%APPDATA%\svchost32\svchost32.exe` and registers service `svchost32` with display name `Cloud Sync Service`.                                      |
| Defense Evasion     | ChocoShell AMSI bypass and sandbox timing checks                                          | Microsoft reports ChocoShell disables AMSI via .NET reflection and exits under timing-based sandbox detection.                                                         |
| Credential Access   | Browser password/cookie, Microsoft 365 SSO, Azure/Entra token, and Wi-Fi credential theft | ChocoShell is described as an in-memory PowerShell stealer focused on these artifacts.                                                                                 |
| Command and Control | Encrypted CornFlake C2 and FruitStone operator panel                                      | Microsoft describes ECDH P-256 session key exchange, encrypted JSON protocol, and the FruitStone web panel.                                                            |
| Collection          | Screenshots, keylogging, clipboard,                                                       | Microsoft describes these CornFlake                                                                                                                                    |

|  |                                                            |                                              |
|--|------------------------------------------------------------|----------------------------------------------|
|  | audio/video, file exfiltration, removable-media monitoring | capabilities and FruitStone tasking options. |
|--|------------------------------------------------------------|----------------------------------------------|

## 7. Infrastructure and Indicators

| Indicator / Infrastructure                                         | Type       | Operational Use                            | First Seen |
|--------------------------------------------------------------------|------------|--------------------------------------------|------------|
| `ms365-device[.]com`                                               | Domain     | CaptiveCrunch device-code-flow redirect    | 2026-07-23 |
| `ms365-live[.]com`                                                 | Domain     | CaptiveCrunch device-code-flow redirect    | 2026-05-14 |
| `m365-owa[.]com`                                                   | Domain     | CaptiveCrunch AitM infrastructure          | 2026-07-20 |
| `owa-ms365[.]com`                                                  | Domain     | CaptiveCrunch AitM infrastructure          | 2026-07-16 |
| `31.57.243[.]154`                                                  | IP address | CaptiveCrunch AitM infrastructure          | 2026-07-16 |
| `38.146.28[.]75`                                                   | IP address | CaptiveCrunch AitM infrastructure          | 2026-07-01 |
| `38.146.28[.]132`                                                  | IP address | CaptiveCrunch DNS resolver                 | 2026-07-15 |
| `104.194.159[.]150`                                                | IP address | CaptiveCrunch AitM infrastructure          | 2026-04-28 |
| `107.189.26[.]194`                                                 | IP address | ChocoShell C2 / CaptiveCrunch DNS resolver | 2026-02-27 |
| `213.145.86[.]112`                                                 | IP address | ChocoShell C2                              | 2026-07-01 |
| `918fa52ae45ed60ba7cc8bdc99c3cbe9ab92e0375ec31fc05d0d4513be11c593` | SHA-256    | CornFlake                                  | 2026-07-03 |
| `be99857449d2856dd5a84e21c8a3d5e0e01456adb44062ddec5a6b4970d8d42c` | SHA-256    | ChocoShell                                 | 2026-07-10 |

## 8. Malware and Tooling Notes

### 8.1. CornFlake

CornFlake is reported as a full-featured Windows RAT written in Go. On execution, it displays a fake progress window while copying itself to `%APPDATA%\svchost32\svchost32.exe`, establishing persistence, and registering a service named `svchost32` with display name `Cloud Sync Service`. Microsoft describes configurable fake window lures including Windows Update, Windows Defender, DirectX, Visual C++ redistributable, disk optimization, network diagnostics, browser update, and document viewer themes.

CornFlake's collection and access capabilities reportedly include system enumeration, keylogging, clipboard monitoring, screenshots, audio/video surveillance, browser credential theft, file exfiltration, removable-media monitoring, and remote shell access. It uses an encrypted C2 channel with ECDH P-256 ephemeral key exchange and a custom JSON protocol. Runtime configuration in `sync.dat` supports hot reconfiguration of C2 servers, watched directories, and file targeting.

## 8.2. ChocoShell

ChocoShell is a PowerShell-based infostealer delivered and executed in memory. Its primary collection targets are browser session cookies, saved passwords, Microsoft 365 SSO tokens, Azure/Entra authentication tokens, Token Broker cache `.tbres` artifacts, and saved Wi-Fi credentials. Microsoft reports a hardcoded beacon to `213.145.86[.]112`, `/t/pixel.gif?m=<status>` beacons, download of `/cdn/chunks/polyfill-7e2b.min.js`, and POST exfiltration to `/t/event` using compressed/base64-wrapped JSON.

## 8.3. FruitStone

FruitStone is the reported operator panel used to manage campaign infrastructure, branded as `CloudSync Console` / `Acuity Systems, Inc. -- Cloud Infrastructure Portal v3.2.1`. The panel reportedly supports agent dashboards, remote shell, file browsing and download, screenshot/process/keylog/clipboard/posture collection, live configuration push, agent updates, proxy relays, beacon profiles, and staging-server management.

## 9. Detection Engineering

This section provides deployable starting points. Validate them in local telemetry before production alerting, because public indicators may change and some behavior overlaps with benign captive-portal and software-update activity.

### 9.1. Detection Summary

| Signal                                                                 | Telemetry Source                                              | Analytic Goal                                                              |
|------------------------------------------------------------------------|---------------------------------------------------------------|----------------------------------------------------------------------------|
| Known CaptiveCrunch domains/IPs                                        | DNS, proxy, EDR network telemetry, SIEM threat-intel matching | Identify direct contact with published phishing/C2/DNS infrastructure.     |
| File creation within two minutes of captive-portal connectivity checks | EDR network + file telemetry                                  | Detect fake update payload delivery after NCSI/captive-portal redirection. |
| `%APPDATA%\svchost32\svchost32.exe` execution                          | EDR process/file telemetry                                    | Detect CornFlake staging and persistence path.                             |
| Service `svchost32` / display name `Cloud Sync Service`                | Windows service/registry telemetry                            | Detect CornFlake persistence masquerading as cloud sync.                   |
| PowerShell AMSI bypass and web fetch to `213.145.86[.]112`             | PowerShell, EDR, proxy logs                                   | Detect ChocoShell execution and C2.                                        |
| Anomalous device-code authentication                                   | Entra ID sign-in logs, Defender for Identity/XDR              | Detect actor-controlled device-code session grants.                        |

### 9.2. Sigma: CornFlake Persistence Service

```

title: Potential CornFlake Cloud Sync Service Persistence
id: 5a52f4e8-cdde-4ef2-bf9b-3e7d8b205961
status: experimental
description: Detects service/registry artifacts reported for CornFlake in the CaptiveCrunch campaign.
references:
  - https://www.microsoft.com/en-us/security/blog/2026/07/31/captivecrunch-midnight-blizzard-targets-travelers-worldwide-for-malware-delivery-and-credential-theft/
author: Lost Boys Cyber
date: 2026-08-04
tags:
  - attack.persistence
  - attack.t1543.003
  - attack.t1060
logsource:
  product: windows
  category: registry_set
detection:
  selection_service_key:

```

```

TargetObject|contains: '\SYSTEM\CurrentControlSet\Services\svchost32'
selection_display:
  Details|contains:
    - 'Cloud Sync Service'
    - 'Synchronizes files with the cloud storage provider'
selection_path:
  Details|contains: '\svchost32\svchost32.exe'
condition: selection_service_key or selection_display or selection_path
falsepositives:
  - Legitimate in-house service coincidentally named svchost32; investigate publisher, path, and parent process.
level: high

```

### 9.3. Sigma: ChocoShell PowerShell C2 Indicators

```

title: Potential ChocoShell PowerShell C2 Traffic
id: c81a53a5-1d70-48a4-9d95-2e2a786a0961
status: experimental
description: Detects PowerShell command lines or network URLs matching ChocoShell paths reported in CaptiveCrunch.
references:
  - https://www.microsoft.com/en-us/security/blog/2026/07/31/captivecrunch-midnight-blizzard-targets-travelers-worldwide-for-malware-delivery-and-credential-theft/
author: Lost Boys Cyber
date: 2026-08-04
tags:
  - attack.execution
  - attack.t1059.001
  - attack.command_and_control
logsource:
  product: windows
  category: process_creation
detection:
  selection_ps:
    Image|endswith:
      - '\powershell.exe'
      - '\pwsh.exe'
  selection_ioc:
    CommandLine|contains:
      - '213.145.86.112'
      - '/t/pixel.gif'
      - '/cdn/chunks/polyfill-7e2b.min.js'
      - '/t/event'
      - 'ScriptBlock]::Create'
  condition: selection_ps and selection_ioc
falsepositives:
  - Security testing that intentionally replays public indicators.
level: high

```

### 9.4. YARA: CaptiveCrunch Public Artifact Strings

```

rule LBC_CaptiveCrunch_Public_Artifact_Strings
{
  meta:
    description = "Hunts for public strings associated with CaptiveCrunch CornFlake/ChocoShell artifacts"
    author = "Lost Boys Cyber"
    date = "2026-08-04"
    reference = "https://www.microsoft.com/en-us/security/blog/2026/07/31/captivecrunch-midnight-blizzard-targets-travelers-worldwide-for-malware-delivery-and-credential-theft/"
    confidence = "medium"
  strings:
    $svc1 = "Cloud Sync Service" ascii wide
    $svc2 = "Synchronizes files with the cloud storage provider" ascii wide
    $path1 = "svchost32\svchost32.exe" ascii wide
    $cfg1 = "sync.dat" ascii wide
    $uri1 = "/t/pixel.gif" ascii wide

```



```

    $uri2 = "/cdn/chunks/polyfill-7e2b.min.js" ascii wide
    $uri3 = "/t/event" ascii wide
    $brand1 = "CloudSync Console" ascii wide
    $brand2 = "Acuity Systems, Inc." ascii wide
    condition:
        2 of ($svc*) or (1 of ($uri*) and 1 of ($svc*, $path1, $cfg1)) or all of ($brand*)
}

```

## 9.5. KQL: Known Infrastructure Contact

```

let CaptiveCrunchDomains = dynamic(["ms365-device.com", "ms365-live.com", "m365-owa.com", "owa-
ms365.com"]);
let CaptiveCrunchIPs = dynamic(["31.57.243.154", "38.146.28.75", "38.146.28.132", "104.194.159.150",
"107.189.26.194", "213.145.86.112"]);
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any (CaptiveCrunchDomains) or RemoteIP in (CaptiveCrunchIPs)
| project Timestamp, DeviceName, DeviceId, RemoteUrl, RemoteIP, LocalIP, InitiatingProcessFileName,
InitiatingProcessCommandLine, InitiatingProcessAccountName, ReportId
| order by Timestamp desc

```

## 9.6. KQL: Download After Captive-Portal Connectivity Check

```

let ncsi_endpoints = dynamic(["msftconnecttest.com", "edge-
http.microsoft.com", "msftncsi.com", "captive.apple.com", "clients1.google.com", "clients3.google.com", "cli
ents4.google.com", "clients6.google.com", "connectivitycheck.gstatic.com", "connectivitycheck.android.com"
, "android.clients.google.com", "www.gstatic.com", "detectportal.firefox.com", "detectportal.brave-http-
only.com", "cloudflareportal.com", "cloudflarecp.com", "cloudflareok.com", "connectivity-check.warp-
svc", "connectivity.cloudflareclient.com", "spectrum.s3.amazonaws.com", "nmcheck.gnome.org"]);
let NCSIEvents = DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemoteUrl has_any (ncsi_endpoints)
| project NCSI_Timestamp = Timestamp, DeviceId, DeviceName, RemoteUrl, NCSI_Process =
InitiatingProcessFileName, NCSI_CommandLine = InitiatingProcessCommandLine;
let FileDownloadEvents = DeviceFileEvents
| where Timestamp > ago(14d)
| where ActionType == "FileCreated"
| where FileName endswith ".exe" or FileName endswith ".msi" or FileName endswith ".zip" or FileName
endswith ".rar" or FileName endswith ".7z" or FileName endswith ".apk"
| project Download_Timestamp = Timestamp, DeviceId, FileName, FolderPath, Download_Process =
InitiatingProcessFileName, Download_CommandLine = InitiatingProcessCommandLine, Download_AccountName =
InitiatingProcessAccountName;
NCSIEvents
| join kind=inner FileDownloadEvents on DeviceId
| where Download_Timestamp between (NCSI_Timestamp .. NCSI_Timestamp + 2m)
| project NCSI_Timestamp, Download_Timestamp, DeviceName, DeviceId, RemoteUrl, FileName, FolderPath,
Download_Process, Download_CommandLine, Download_AccountName
| order by Download_Timestamp desc

```

# 10. Threat Hunting

## 10.1. Hunt Hypothesis 1: Captive portal redirected a traveler to malicious infrastructure

If an endpoint contacted captive-portal connectivity-check domains and then quickly downloaded an executable or contacted a CaptiveCrunch IOC, the system may have been exposed to fake update delivery.

```

let CaptiveCrunchDomains = dynamic(["ms365-device.com", "ms365-live.com", "m365-owa.com", "owa-
ms365.com"]);
let CaptiveCrunchIPs = dynamic(["31.57.243.154", "38.146.28.75", "38.146.28.132", "104.194.159.150",
"107.189.26.194", "213.145.86.112"]);
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any (CaptiveCrunchDomains) or RemoteIP in (CaptiveCrunchIPs)
| join kind=leftouter (
    DeviceInfo
    | summarize arg_max(Timestamp, *) by DeviceId
    | project DeviceId, LoggedOnUsers, PublicIP, OSPlatform, DeviceType

```

```

) on DeviceId
| project Timestamp, DeviceName, DeviceId, RemoteUrl, RemoteIP, InitiatingProcessFileName,
InitiatingProcessCommandLine, LoggedOnUsers, PublicIP, OSPlatform

```

## 10.2. Hunt Hypothesis 2: CornFlake persistence was installed under the masqueraded Cloud Sync service

```

DeviceRegistryEvents
| where Timestamp > ago(30d)
| where RegistryKey has @("\SYSTEM\CurrentControlSet\Services\svchost32"
or RegistryValueData has_any ("Cloud Sync Service", "Synchronizes files with the cloud storage
provider", @"\svchost32\svchost32.exe")
| project Timestamp, DeviceName, DeviceId, RegistryKey, RegistryValueName, RegistryValueData,
ActionType, InitiatingProcessFileName, InitiatingProcessCommandLine, InitiatingProcessAccountName,
ReportId
| order by Timestamp desc

```

## 10.3. Hunt Hypothesis 3: Device-code authentication was abused during travel

```

SigninLogs
| where TimeGenerated > ago(30d)
| where AuthenticationProtocol =~ "deviceCode" or ClientAppUsed has "Device" or ResultDescription has
"device code"
| extend User = coalesce(UserPrincipalName, Identity)
| project TimeGenerated, User, AppDisplayName, ClientAppUsed, IPAddress, Location,
ConditionalAccessStatus, RiskLevelDuringSignIn, RiskDetail, ResultType, ResultDescription,
CorrelationId
| order by TimeGenerated desc

```

## 10.4. Hunt Hypothesis 4: PowerShell attempted ChocoShell-style token theft or C2

```

DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("powershell.exe", "pwsh.exe")
| where ProcessCommandLine has_any ("213.145.86.112", "/t/pixel.gif",
"/cdn/chunks/polyfill-7e2b.min.js", "/t/event", "ScriptBlock]::Create", "AMSI", "TokenBroker",
".tbres")
| project Timestamp, DeviceName, DeviceId, AccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName, InitiatingProcessCommandLine, ReportId
| order by Timestamp desc

```

## 11. Risk Assessment

| Dimension               | Assessment                                                                                    | Rationale                                                                                                                                                                              |
|-------------------------|-----------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Likelihood              | Medium to High for frequent travelers and event attendees                                     | The campaign is active and uses common travel workflows; exposure depends on venue and network controls.                                                                               |
| Impact                  | High                                                                                          | Successful device-code abuse or token theft can bypass normal password-only controls and grant cloud access; CornFlake/ChocoShell add endpoint surveillance and credential collection. |
| Detectability           | Medium                                                                                        | Published IOCs and artifacts are detectable, but AitM phishing and device-code flows can appear as legitimate sign-ins unless identity telemetry is mature.                            |
| Intelligence Confidence | High for campaign existence and Microsoft-attributed details; Medium for venue/provider scope | Microsoft is the primary source, but public reporting does not name affected vendors or quantify successful compromises.                                                               |

## 12. Recommended Actions

| Priority | Owner                          | Action                                                                                                                                                                            |
|----------|--------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Critical | Identity Engineering           | Block Microsoft Entra device-code flow unless there is a documented business need; where needed, restrict by user group, device compliance, location, and phishing-resistant MFA. |
| Critical | Travel Security / IT           | Default executives and high-risk travelers to cellular/eSIM or enterprise-managed full-tunnel connectivity; discourage hotel/conference Wi-Fi for sensitive work.                 |
| High     | SOC                            | Load the published CaptiveCrunch IOCs into SIEM/XDR watchlists and alert on any endpoint, DNS, proxy, or identity telemetry match.                                                |
| High     | Endpoint Engineering           | Alert on `%APPDATA%\svchost32\svchost32.exe`, service `svchost32`, display name `Cloud Sync Service`, suspicious Run keys, and scheduled tasks using the same path.               |
| High     | SOC / Detection Engineering    | Deploy hunts for downloads immediately following captive-portal connectivity checks, followed by process execution or network connections to new infrastructure.                  |
| High     | Identity/SOC                   | Review recent device-code sign-ins, OAuth grants, risky sign-ins, MFA-satisfied sign-ins from travel locations, and suspicious Microsoft Graph access following travel windows.   |
| Medium   | Awareness / Executive Support  | Train travelers to reject updates, certificates, troubleshooting tools, or paste-and-run instructions presented by captive portals or unexpected browser pages.                   |
| Medium   | Hospitality Risk / Procurement | For corporate events, ask venues and captive-portal providers about management-plane security, DNS resolver controls, logging retention, and incident notification obligations.   |

## 13. Incident Response Playbook

1. Identify users/devices that connected to known affected venues or that contacted CaptiveCrunch infrastructure.
2. Isolate devices with CornFlake/ChocoShell indicators or suspicious downloads after captive-portal checks.
3. Revoke refresh tokens and sessions for affected users; reset credentials only after token/session revocation is complete.
4. Review Entra audit/sign-in logs for device-code flow, anomalous OAuth grants, new device registration, risky sign-in, impossible travel, and Microsoft Graph email/file access.

5. Acquire endpoint triage: process tree, service list, scheduled tasks, Run keys, PowerShell logs, browser profile artifacts, Token Broker cache metadata, `%APPDATA%\svchost32\`, and EDR timeline.
6. Search enterprise-wide for shared IOCs, service names, hashes, and suspicious post-connectivity-check downloads.
7. If hospitality provider infrastructure is involved, preserve DNS/proxy/captive-portal logs and coordinate with the venue/provider for source IPs, configuration changes, and administrative access logs.

## 14. MITRE ATT&CK Mapping

| Technique | Name                                                               | CaptiveCrunch Relevance                                                           |
|-----------|--------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| T1557     | Adversary-in-the-Middle                                            | Captive-portal traffic manipulation and AitM phishing.                            |
| T1556.006 | Multi-Factor Authentication Request Generation / Device Code Abuse | Victim enters attacker-controlled device code into legitimate sign-in.            |
| T1059.001 | PowerShell                                                         | ChocoShell in-memory PowerShell stealer.                                          |
| T1204.002 | User Execution: Malicious File                                     | Fake update/ClickFix flows require user download or execution.                    |
| T1543.003 | Create or Modify System Process: Windows Service                   | CornFlake registers a masqueraded service.                                        |
| T1060     | Registry Run Keys / Startup Folder                                 | CornFlake Run-key persistence.                                                    |
| T1053.005 | Scheduled Task                                                     | CornFlake scheduled-task persistence.                                             |
| T1555.003 | Credentials from Web Browsers                                      | Browser cookies/passwords targeted by ChocoShell/CornFlake.                       |
| T1528     | Steal Application Access Token                                     | Microsoft 365/Azure/Entra tokens targeted by ChocoShell and device-code phishing. |
| T1113     | Screen Capture                                                     | CornFlake screenshot capability.                                                  |
| T1056.001 | Keylogging                                                         | CornFlake keylogging capability.                                                  |
| T1123     | Audio Capture                                                      | CornFlake microphone/audio surveillance.                                          |
| T1125     | Video Capture                                                      | CornFlake webcam/video surveillance.                                              |
| T1041     | Exfiltration Over C2 Channel                                       | CornFlake/ChocoShell exfiltration over actor C2.                                  |

## 15. References

- [1] Microsoft Security Blog. "CaptiveCrunch: Midnight Blizzard targets travelers worldwide for malware delivery and credential theft." 2026-07-31. <https://www.microsoft.com/en-us/security/blog/2026/07/31/captivecrunch-midnight-blizzard-targets-travelers-worldwide-for-malware-delivery-and-credential-theft/>
- [2] Help Net Security. "Russian hackers abuse hotel Wi-Fi networks to steal Microsoft 365 logins." 2026-08-04. <https://www.helpnetsecurity.com/2026/08/04/midnight-blizzard-hotel-wi-fi-networks-hacking/>
- [3] Malwarebytes. "Travelers targeted when logging into hotel Wi-Fi networks." 2026-08-04. <https://www.malwarebytes.com/blog/news/2026/08/travelers-targeted-when-logging-into-hotel-wi-fi-networks>
- [4] The Hacker News. "Hijacked Hotel Wi-Fi Pushes Fake Updates to Deliver Surveillance Malware." 2026-08-01/04. <https://thehackernews.com/2026/08/hijacked-hotel-wi-fi-pushes-fake.html>

- [5] ReliaQuest. "Threat Spotlight: DNS Poisoning Tactics Expand to Hospitality." Referenced by Microsoft, 2026-07-23. <https://reliaquest.com/blog/threat-spotlight-dns-poisoning-tactics-expand-to-hospitality/>